

SQL SERVER 2022 • AVANZADO

Seguridad avanzada y protección de datos en SQL Server 2022

Sesión 5 de 6 • Always Encrypted con enclaves, Ledger, RLS, Dynamic Data Masking, roles granulares, auditoría y hardening

Empezar por el modelo de amenazas

- ¿De quién nos protegemos? Atacante externo, usuario de negocio curioso, DBA o administrador de sistemas, proveedor cloud
- ¿Qué protegemos? Confidencialidad (que no se lea), integridad (que no se altere), trazabilidad (quién hizo qué)
- ¿Dónde está el dato? En disco, en backups, en la red, en memoria del servidor, en la aplicación
- Cada funcionalidad cubre una celda de esta matriz, ninguna las cubre todas
- LegacyShop hoy: IBAN, fecha de nacimiento, email y teléfono en claro, legibles por cualquier usuario

Pregunta incómoda

Si un DBA con sysadmin puede leer los IBAN de todos vuestros clientes, ¿cumplís el principio de minimización del RGPD? Always Encrypted es la única funcionalidad de esta sesión que protege incluso frente a él.

Mapa de funcionalidades frente a amenazas

Confidencialidad

- TDE y cifrado de backups: disco y copias robadas
- TLS / TDS 8.0: datos en la red
- Always Encrypted: incluso frente a DBA y sysadmin
- Dynamic Data Masking: ofuscación en presentación
- Row-Level Security: qué filas ve cada usuario

Integridad y trazabilidad

- Ledger: detección criptográfica de manipulaciones
- SQL Server Audit: quién accedió o cambió qué
- Tablas temporales: historial de versiones (no a prueba de manipulación)
- Roles granulares 2022: mínimo privilegio real
- Hardening: reducir la superficie de ataque

01

Always Encrypted con enclaves seguros

Cifrado en el cliente: el motor nunca ve las claves ni los datos en claro

Cómo funciona Always Encrypted



Determinista: permite igualdad, joins, GROUP BY e índices (y revela patrones). Aleatorio: más seguro, sin operaciones sin enclave.

Enclaves seguros: calcular sin revelar

- Un enclave es una región de memoria protegida dentro del proceso de SQL Server, inaccesible incluso para el sistema operativo
- VBS (Virtualization-Based Security): solo Windows; atestación con HGS o sin atestación en entornos de prueba
- El cliente envía la clave al enclave por un canal seguro tras verificar (atestar) que es legítimo
- Permite con cifrado aleatorio: comparaciones de rango, LIKE, índices y cifrado in situ sin mover datos
- 2022 amplía las operaciones dentro del enclave (joins, GROUP BY, ORDER BY) y el soporte UTF-8

Honestidad sobre el temario

"Sin perder capacidad de cálculo" es cierto solo en parte: con enclaves se pueden hacer muchas operaciones, pero no todas, y cada una tiene coste. Y en Linux (nuestro contenedor) no hay enclaves: se usa Always Encrypted sin enclave.

Always Encrypted: lo que ve cada uno

```
-- Claves (normalmente creadas con el asistente de SSMS o PowerShell)
CREATE COLUMN MASTER KEY CMK_LegacyShop WITH (
    KEY_STORE_PROVIDER_NAME = N'MSSQL_CERTIFICATE_STORE',
    KEY_PATH = N'CurrentUser/My/<huella_del_certificado>');
-- CREATE COLUMN ENCRYPTION KEY CEK_LegacyShop ... (valor cifrado generado por la herramienta)

-- Columna cifrada (tabla nueva o mediante el asistente de cifrado)
IBAN varchar(34) COLLATE Latin1_General_BIN2
    ENCRYPTED WITH (COLUMN_ENCRYPTION_KEY = CEK_LegacyShop,
        ENCRYPTION_TYPE = DETERMINISTIC,
        ALGORITHM = 'AEAD_AES_256_CBC_HMAC_SHA_256')

-- Sin Column Encryption Setting: IBAN = 0x01A3F9... (binario cifrado)
-- Con Column Encryption Setting=Enabled y acceso a la CMK: ES91 2100 0418 ...
-- Filtrar exige parámetros (no literales): WHERE IBAN = @iban
```

Las cadenas cifradas de forma determinista requieren una intercalación BIN2.

Lab 9 · Always Encrypted en LegacyShop

- Crear CMK y CEK con el asistente de SSMS (cliente Windows)
- Cifrar IBAN (determinista) y FechaNacimiento (aleatorio)
- Comparar lo que ve una conexión con y sin Column Encryption Setting
- Comprobar qué consultas fallan con cifrado aleatorio sin enclave
- Demostrar que un sysadmin sin acceso a la CMK no puede leer los datos

40 min

labs/
Lab09_Always_Encrypted.md

02

Ledger for SQL Server

Tablas con evidencia criptográfica de manipulación

Ledger: qué es y qué no es

1

Tablas actualizables

Permiten INSERT, UPDATE y DELETE. Cada cambio queda en una tabla de historial y una vista de ledger muestra todas las operaciones.

2

Tablas solo inserción

Append-only: solo INSERT. Ideales para logs de auditoría, eventos de seguridad o registros contables.

3

Digest de base de datos

Hash raíz que resume todas las transacciones. Guardado fuera del alcance del DBA, permite verificar la integridad.

4

Qué NO es

No es una blockchain descentralizada ni impide manipular: detecta que ha habido manipulación. Tampoco cifra.

Ledger en la práctica

```
-- Tabla actualizable (se crea nueva: no se puede convertir una tabla existente)
CREATE TABLE dbo.PreciosProducto (
    ProductoID int NOT NULL PRIMARY KEY, Precio decimal(10,2) NOT NULL,
    ModificadoPor sysname NOT NULL DEFAULT SUSER_SNAME())
WITH (SYSTEM_VERSIONING = ON, LEDGER = ON);

-- Tabla de solo inserción
CREATE TABLE dbo.EventosSeguridad (Fecha datetime2 DEFAULT SYSUTCDATETIME(),
    Usuario sysname, Evento nvarchar(400)) WITH (LEDGER = ON (APPEND_ONLY = ON));

-- Quién cambió qué y cuándo
SELECT * FROM dbo.PreciosProducto_Ledger ORDER BY ledger_transaction_id;

-- Generar el digest (guardarlo FUERA del servidor) y verificar
EXEC sys.sp_generate_database_ledger_digest;
EXEC sys.sp_verify_database_ledger N'<json de digests guardados>';
```

Migrar datos existentes a una tabla ledger: sys.sp_copy_data_in_batches. Una tabla ledger no se puede convertir en normal.

03

Control de acceso granular

Row-Level Security, Dynamic Data Masking y los nuevos permisos de SQL Server 2022

Row-Level Security

```
CREATE SCHEMA Seguridad;
GO
CREATE FUNCTION Seguridad.fn_PedidosVisibles(@ComercialID int)
RETURNS TABLE WITH SCHEMABINDING AS
RETURN SELECT 1 AS permitido
        WHERE @ComercialID = CAST(SESSION_CONTEXT(N'ComercialID') AS int)
        OR IS_MEMBER('rol_direccion') = 1;
GO
CREATE SECURITY POLICY Seguridad.PoliticaPedidos
    ADD FILTER PREDICATE Seguridad.fn_PedidosVisibles(ComercialID) ON dbo.Pedidos,
    ADD BLOCK PREDICATE Seguridad.fn_PedidosVisibles(ComercialID) ON dbo.Pedidos AFTER INSERT
WITH (STATE = ON);

-- La aplicación, tras autenticar al usuario, fija el contexto (conexiones en pool)
EXEC sp_set_session_context @key = N'ComercialID', @value = 7, @read_only = 1;
```

Función en línea y columnas del predicado indexadas: el filtro se añade a cada consulta sobre la tabla.

Dynamic Data Masking y UNMASK granular (2022)

```
ALTER TABLE dbo.Clientes ALTER COLUMN Email
  ADD MASKED WITH (FUNCTION = 'email()');           -- jXXX@XXXX.com
ALTER TABLE dbo.Clientes ALTER COLUMN Telefono
  ADD MASKED WITH (FUNCTION = 'partial(0,"XXX-XXX-",3)'); -- XXX-XXX-123
ALTER TABLE dbo.Clientes ALTER COLUMN FechaNacimiento
  ADD MASKED WITH (FUNCTION = 'datetime("Y")');      -- nuevo en 2022: oculta el año

-- 2022: UNMASK a nivel de base de datos, esquema, tabla o columna
GRANT UNMASK ON dbo.Clientes(Telefono) TO rol_atencion_cliente;

-- Limitación: el filtro opera sobre el valor real
SELECT ClienteID, Email FROM dbo.Clientes
WHERE Email LIKE 'a%';  -- devuelve máscaras... pero revela qué emails empiezan por "a"
```

DDM es una medida de presentación para reducir exposición en pantallas y exportaciones, no una frontera de seguridad.

Mínimo privilegio real: novedades de 2022

- Nuevos roles de servidor fijos: `##MS_ServerStateReader##`, `##MS_DefinitionReader##`, `##MS_DatabaseConnector##`, `##MS_LoginManager##`...
- Nuevos permisos: `VIEW SERVER PERFORMANCE STATE`, `VIEW SERVER SECURITY STATE`, `VIEW ANY PERFORMANCE DEFINITION`...
- Separan "ver rendimiento" de "ver seguridad": monitorización sin acceso a configuración sensible
- Evitar `sysadmin` para herramientas de monitorización y cuentas de servicio
- Revisar periódicamente miembros de `sysadmin`, `db_owner` y permisos `CONTROL SERVER`

Ejemplo típico

La herramienta de monitorización pedía `sysadmin` para leer DMVs. En 2022 basta con `##MS_ServerPerformanceStateReader##` y `##MS_DefinitionReader##`: lee rendimiento y esquemas, pero no datos ni configuración de seguridad.

Lab 10 · Ledger, RLS, DDM y roles

- Crear PreciosProducto como ledger, modificar precios y auditar la vista de ledger
- Manipular una fila "por la puerta de atrás" y detectarlo con `sp_verify_database_ledger`
- Implantar RLS sobre Pedidos con `SESSION_CONTEXT` y probar con tres usuarios
- Enmascarar Email, Telefono y FechaNacimiento y conceder UNMASK por columna
- Sustituir el sysadmin del usuario de monitorización por roles `##MS_...##`

50 min

labs/
Lab10_Ledger_RLS_DDM.md

04

Auditoría y endurecimiento del servidor

SQL Server Audit, configuración segura y hardening

SQL Server Audit

```
USE master;
CREATE SERVER AUDIT Audit_LegacyShop
    TO FILE (FILEPATH = '/var/opt/mssql/audit/', MAXSIZE = 256 MB, MAX_ROLLOVER_FILES = 20)
    WITH (QUEUE_DELAY = 1000, ON_FAILURE = CONTINUE);
ALTER SERVER AUDIT Audit_LegacyShop WITH (STATE = ON);

CREATE SERVER AUDIT SPECIFICATION Spec_Servidor FOR SERVER AUDIT Audit_LegacyShop
    ADD (FAILED_LOGIN_GROUP), ADD (SERVER_ROLE_MEMBER_CHANGE_GROUP),
    ADD (AUDIT_CHANGE_GROUP), ADD (SERVER_PERMISSION_CHANGE_GROUP) WITH (STATE = ON);

USE LegacyShop;
CREATE DATABASE AUDIT SPECIFICATION Spec_DatosSensibles FOR SERVER AUDIT Audit_LegacyShop
    ADD (SELECT, UPDATE ON dbo.Clientes BY public),
    ADD (DATABASE_PERMISSION_CHANGE_GROUP) WITH (STATE = ON);

SELECT event_time, action_id, server_principal_name, statement
FROM sys.fn_get_audit_file('/var/opt/mssql/audit/*.sqlaudit', DEFAULT, DEFAULT);
```

ON_FAILURE = SHUTDOWN o FAIL_OPERATION garantizan que no hay actividad sin auditar, a costa de disponibilidad.

Checklist de hardening

- Autenticación: Windows/Entra preferente; sa deshabilitado o renombrado; política de contraseñas en logins SQL
- Red: TLS obligatorio (TDS 8.0 y cifrado estricto en 2022), puertos no expuestos, SQL Browser desactivado si no se usa
- Superficie: xp_cmdshell, OLE Automation y Ad Hoc Distributed Queries desactivados; CLR strict security activo
- Cuentas de servicio con mínimo privilegio; ficheros y backups con permisos restringidos y cifrados
- Parches: actualizaciones acumulativas al día; Defender for SQL o evaluación de vulnerabilidades periódica

En el contenedor

La imagen arranca con sa y contraseña en variable de entorno: aceptable para laboratorio, inaceptable en producción. En el Lab 11 veréis la lista de comprobación aplicada a nuestra instancia.

Lab 11 · Auditoría y hardening

- Crear la auditoría de servidor y de base de datos sobre Clientes
- Generar actividad sospechosa y reconstruirla desde el fichero de auditoría
- Intentar desactivar la auditoría y comprobar que queda registrado
- Ejecutar el script de comprobación de hardening y corregir los hallazgos
- Registrar los eventos de seguridad en la tabla ledger append-only

40 min

labs/
Lab11_Auditoria_Hardening.
md

Cierre de la sesión 5

- Primero el modelo de amenazas; después la funcionalidad
- Always Encrypted es la única protección frente al DBA; los enclaves amplían lo que se puede calcular
- Ledger detecta manipulaciones, no las impide; el digest debe custodiarse fuera
- RLS y DDM son barreras para usuarios de aplicación, no fronteras frente a consultas ad hoc
- Próxima sesión: taller integrador. Rescate completo de LegacyShop por equipos

Para la sesión 6

Repasad vuestras notas de las sesiones 1 a 5 y tened a mano las consultas de diagnóstico. En el taller no habrá guía paso a paso: habrá síntomas.